

Volet E : Cybersécurité et Infrastructures Critiques

1. Analyse de risques

Cartographie des actifs

Les principaux actifs du système Néovolt sont :

- Données de consommation énergétique (kWh)
- Données clients (identité, zone, segment)
- Compteurs connectés (id_pdl)
- Plateforme d'analyse (Python, Power BI)
- Fichiers de stockage (CSV / base de données)

Menaces identifiées

- Vol ou fuite de données personnelles
- Modification frauduleuse des données de consommation
- Accès non autorisé aux systèmes
- Panne ou indisponibilité de la plateforme
- Attaques sur les compteurs connectés (IoT)

Vulnérabilités

- Données stockées en fichiers CSV non chiffrés
- Absence de contrôle d'accès fort
- Manque de journalisation des actions
- Communication non sécurisée entre composants
- Dépendance à des scripts locaux non protégés

Scénarios d'attaque

- Injection ou modification de données de consommation pour masquer une fraude
- Accès non autorisé à des fichiers clients
- Exploitation des compteurs pour falsifier les relevés
- Interruption du service d'analyse (attaque sur disponibilité)

Criticité

- Données clients → critique
- Compteurs → critique
- Plateforme d'analyse → élevée
- Visualisation (Power BI) → moyenne

2. Audit de sécurité

Une revue de sécurité du prototype montre plusieurs faiblesses :

- stockage des données en clair (CSV)
- absence d'authentification utilisateur
- absence de chiffrement des données sensibles
- absence de traçabilité (logs)
- accès global aux fichiers sans restriction

Recommandations priorisées

Priorité haute

- Mise en place d'un contrôle d'accès (rôles utilisateurs)
- Chiffrement des données sensibles
- Protection des données clients

Priorité moyenne

- Mise en place de logs d'activité
- Validation des données à l'entrée

Priorité basse

- Amélioration de la structure de stockage
- Séparation des environnements (test / production)

3. Sécurisation de la chaîne (DevSecOps)

La sécurité est intégrée dans tout le cycle de développement :

Développement

- validation des données (suppression des anomalies)
- contrôle de cohérence des datasets

Gestion des identités

- rôles définis :
 - administrateur
 - analyste
 - utilisateur limité

Sécurisation des communications

- utilisation de protocoles sécurisés (HTTPS/TLS)
- chiffrement des données des compteurs connectés
- authentification des dispositifs IoT

4. Détection et réponse (SIEM / SOC)

Plan de supervision

Un système de supervision centralisé permet de surveiller :

- connexions utilisateurs
- accès aux données sensibles
- anomalies de consommation
- comportements suspects

Règles de détection

- multiples tentatives de connexion échouées
- variation brutale de consommation
- accès simultané anormal à plusieurs fichiers

- modification inattendue de données historiques

Runbook de réponse à incident

1. Détection de l'incident via logs
2. Isolation du compte ou système concerné
3. Analyse de la cause
4. Correction de la vulnérabilité
5. Restauration des services
6. Documentation de l'incident

5. Continuité et conformité

Continuité (PCA / PRA)

- sauvegardes régulières des données
- restauration rapide des datasets
- duplication des environnements critiques

Conformité RGPD

- minimisation des données collectées
- protection des données personnelles
- anonymisation des identifiants clients
- limitation des accès aux données sensibles